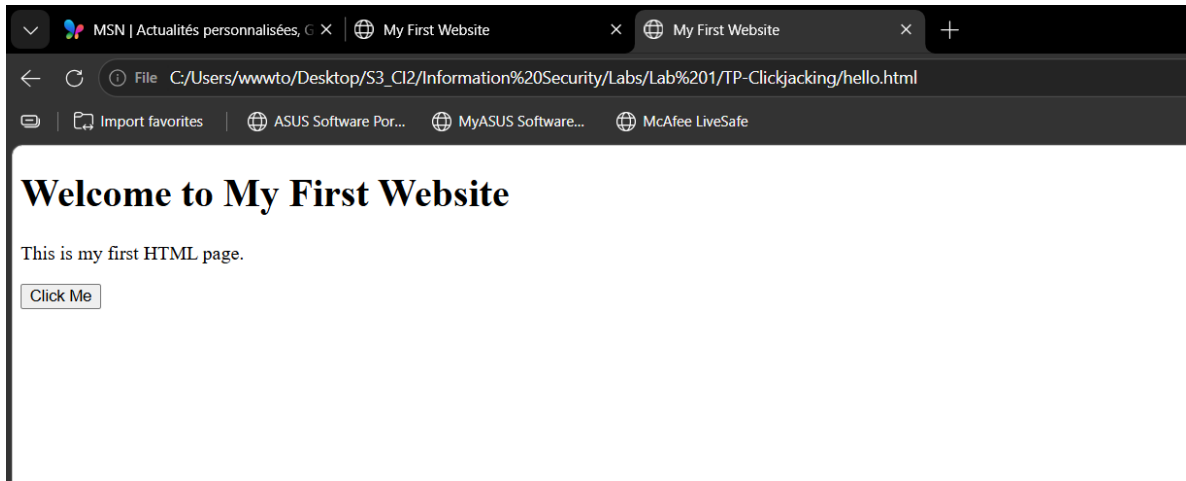


Lab 1 - TP Clickjacking

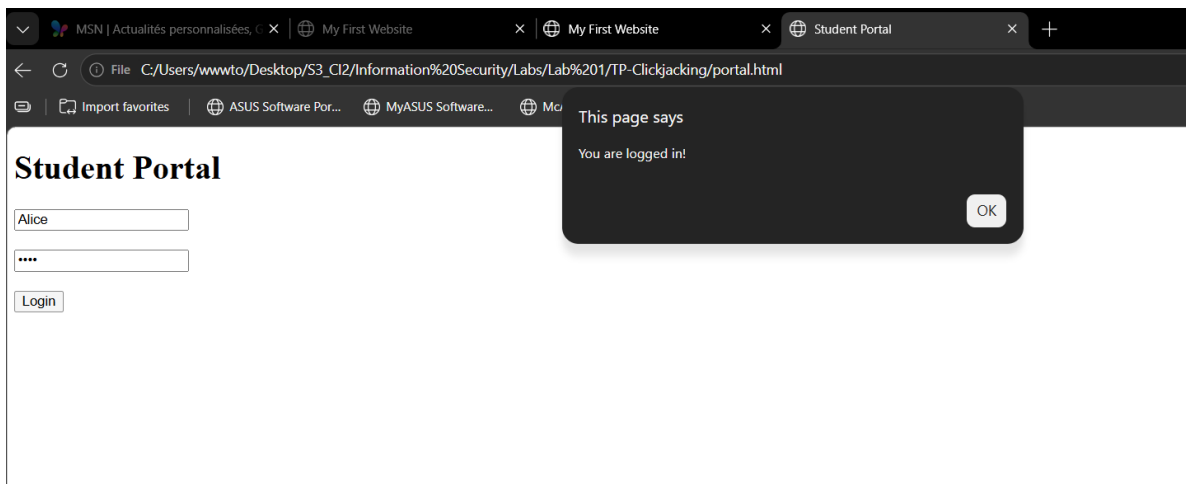
Houda Toudali

Part 1 - HTML Basics



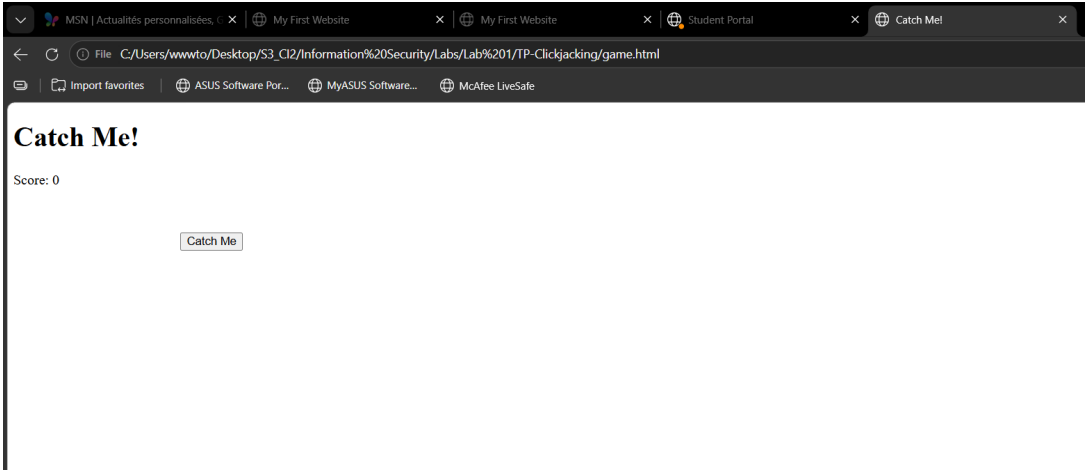
Basic HTML page.

Part 2 - Student Portal

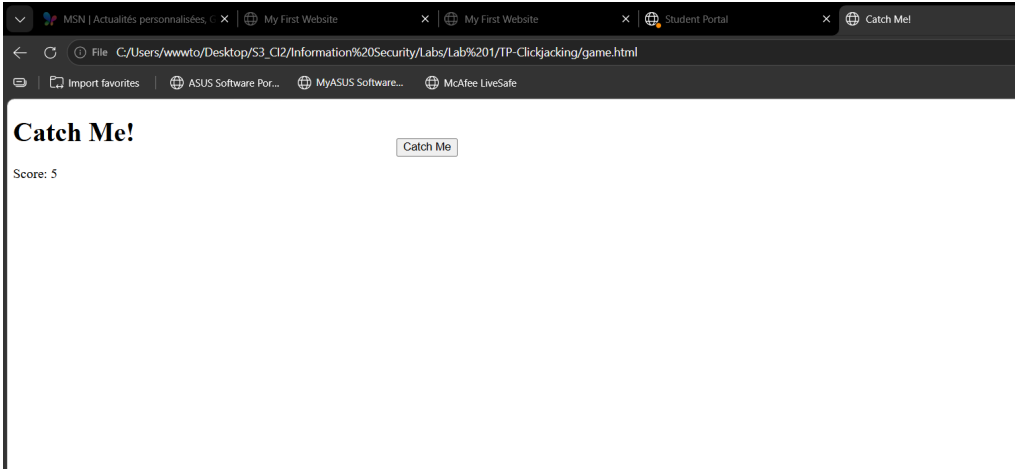


Student Portal login test.

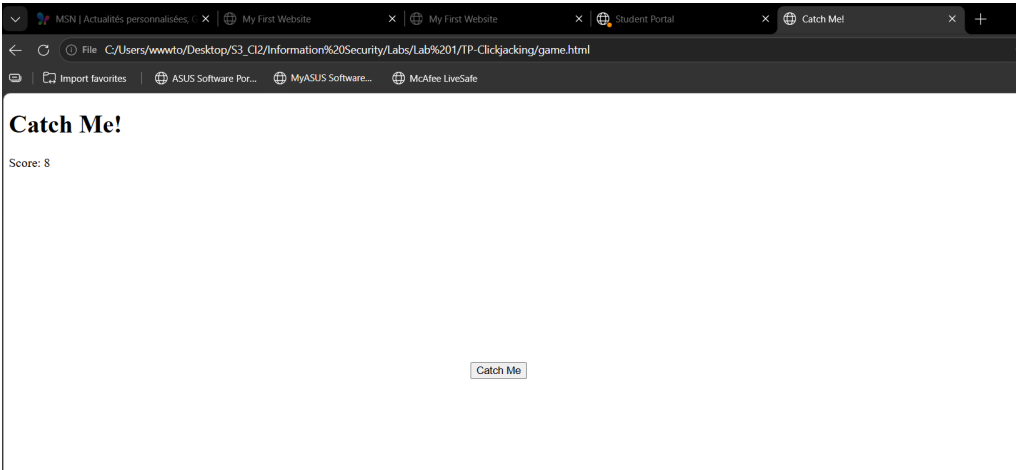
Part 3 - Decoy Game



Initial game state.

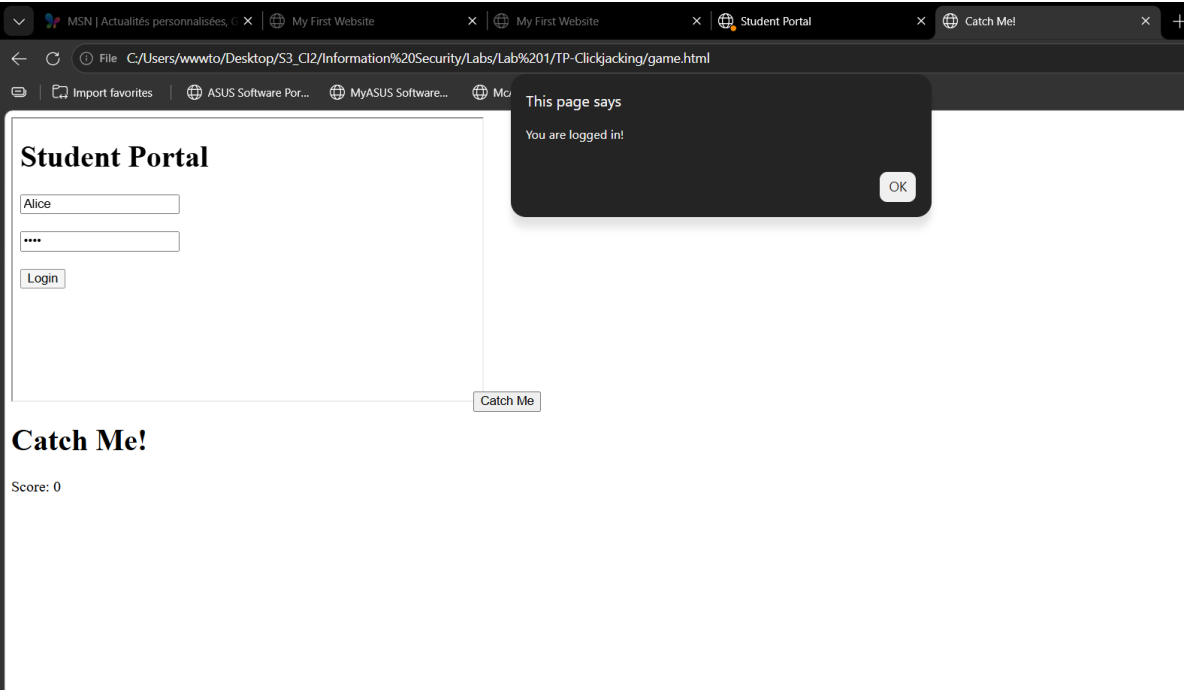


Score update and button movement.



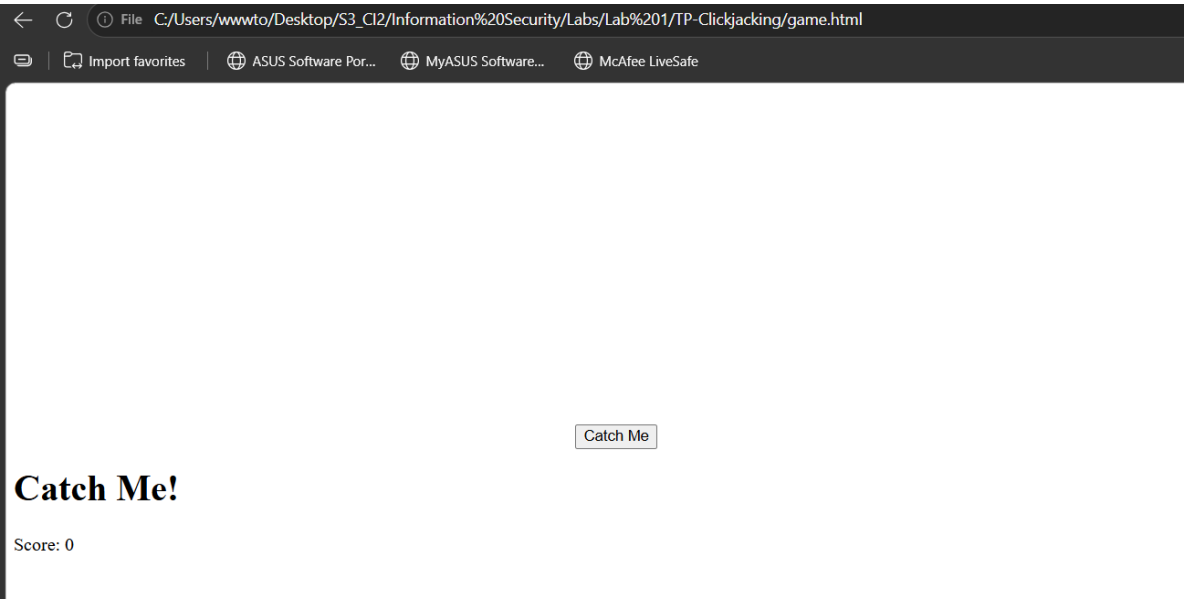
Random button position after multiple clicks.

Part 4 - Iframe Integration



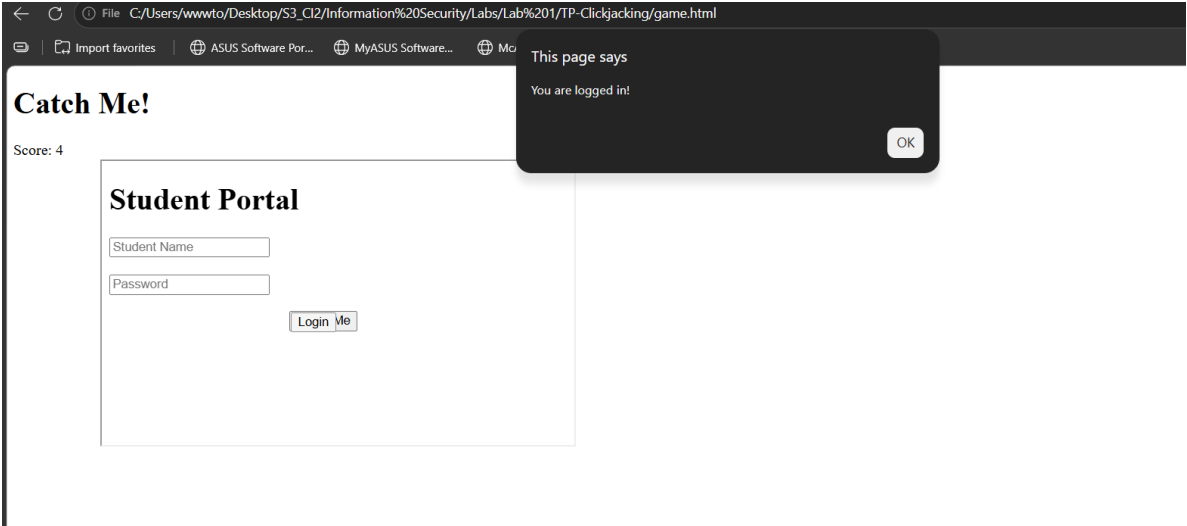
Student Portal embedded in the game page.

Part 5 - Hiding the Student Portal

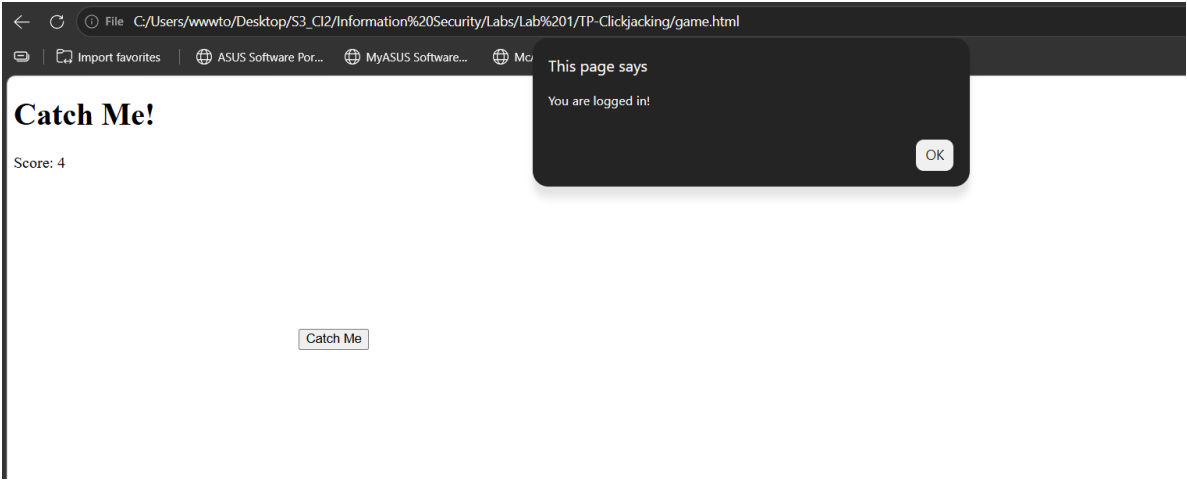


Game page with the iframe hidden.

Part 6 - Clickjacking Moment

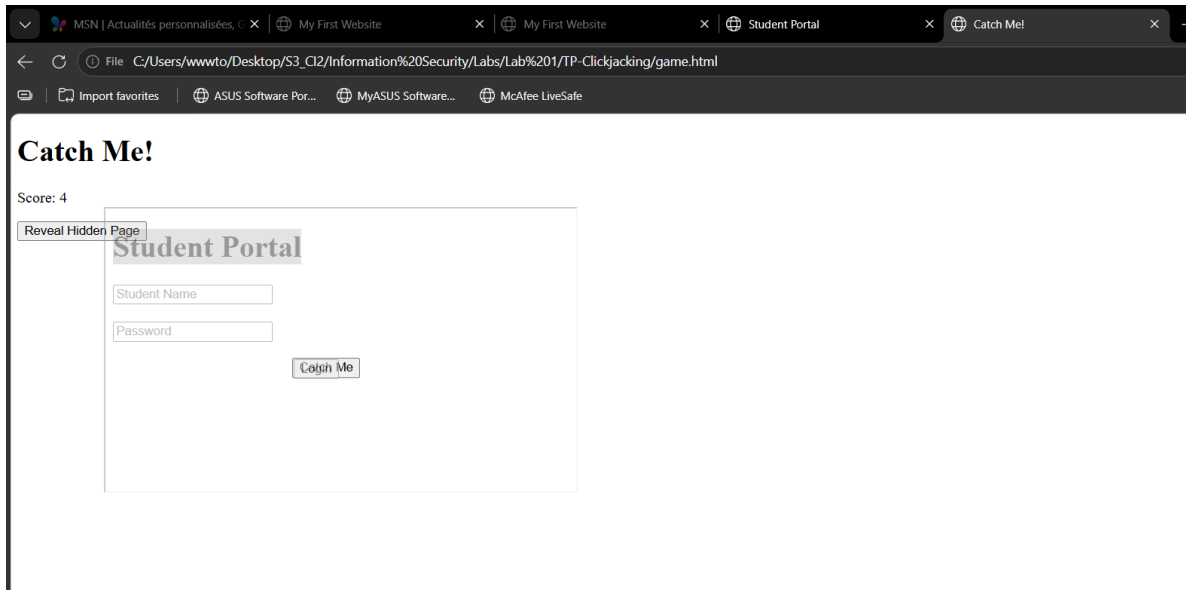


Login and Catch Me buttons aligned.



Clickjacking test result.

Part 7 - Reveal the Attack



Hidden Student Portal revealed with partial opacity.

Part 8 - Anti-Clickjacking Protection

1. What anti-clickjacking protections are available?

The main protections are the `X-Frame-Options` HTTP response header and Content Security Policy (CSP) with the `frame-ancestors` directive. [3]

2. How does each protection control framing?

`X-Frame-Options`: `DENY` blocks framing completely. `SAMEORIGIN` allows framing only from the same origin. [1]

CSP `frame-ancestors` specifies which origins may embed the page. `'none'` blocks all framing, while `'self'` allows same-origin framing. Trusted origins can also be listed explicitly. [2]

3. Which protection allows only same-origin framing?

`X-Frame-Options`: `SAMEORIGIN` or Content-Security-Policy: `frame-ancestors 'self';`. [1, 2]

4. What protection is appropriate for the Student Portal?

Since the portal should not be embedded in another website, a suitable policy is:

Content-Security-Policy: `frame-ancestors 'none';`

`X-Frame-Options`: `DENY` can also be sent. [3, 2]

5. What changes if another trusted university application must embed the portal?

The trusted origin can be added explicitly, for example:

Content-Security-Policy: `frame-ancestors 'self' https://trusted.university.example;`

If both applications use the same origin, `'self'` is enough. [2]

References

- [1] MDN Web Docs, *X-Frame-Options header*.
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>
- [2] MDN Web Docs, *Content-Security-Policy: frame-ancestors directive*.
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Content-Security-Policy/frame-ancestors>
- [3] OWASP Cheat Sheet Series, *Clickjacking Defense Cheat Sheet*.
https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html